

WLAN Tehditleri

WLAN, AP kapsamındaki herkese ve onunla ilişkilendirilecek uygun kimlik bilgilerine açıktır. Saldırıları dışarıdan, hoşnutsuz çalışanlardan ve hatta istemeden çalışanlardan kaynaklanabilir. Kablosuz ağlar, aşağıdakiler de dahil olmak üzere çeşitli tehditlere karşı özellikle hassastır;

- Verilere müdahale
- Kablosuz davetsiz misafirler
- Hizmet Reddi (DoS) Saldırıları
- Rogue-Sahte AP'ler

Dos Attacks

Kablosuz DoS saldırıları aşağıdakilerin sonucunda olabilir;

- Yanlış yapılandırılmış cihazlar
- Kablosuz iletişime kasıtlı olarak müdahale eden kötü niyetli bir kullanıcı
- Yanlışlıkla müdahale

Düzgün yapılandırılmamış aygıtlar ve kötü amaçlı saldırılar nedeniyle DoS saldırısı riskini en aza indirmek için, tüm aygıtları sıkılaştırın, parolaları güvende tutun, yedekler oluşturun ve tüm yapılandırma değişikliklerinin çalışma saatleri dışında dahil edildiğinden emin olun.

Rogue Access Points

- Sahte bir AP, açık bir yetkilendirme olmadan ve şirket politikasına aykırı olarak bir şirket ağına bağlanan bir AP veya kablosuz yönlendiricilerdir.
- Bağlandıktan sonra, sahte AP, saldırgan tarafından MAC adreslerini yakalamak, veri paketlerini yakalamak, ağ kaynaklarına erişmek veya ortadaki adam saldırı başlatmak için kullanılabilir.
- Kişisel bir ağ etkin noktası da sahte bir AP olarak kullanılabilir. Örneğin, güvenli ağ erişimine sahip bir kullanıcı, yetkili Windows ana bilgisayarlarının Wi-Fi AP olmasını sağlar.
- Sahte AP'lerin yüklenmesini önlemek için kuruluşların WLC'leri sahte AP politikalarıyla yapılandırması ve yetkisiz AP'ler için radyo spektrumunu aktif olarak izlemek için izleme yazılımı kullanması gerekir.

Man-in-the-Middle Attack

Ortakdaki adam (MITM) saldırısında, bilgisayar korsanı iki taraf arasında geen verileri okumak veya deęiřtirmek iin iki meřru varlık arasında konumlandırılır. Popler bir kablosuz MITM saldırısına “evil twin AP-kt ikiz AP” saldırısı denir, burada bir saldırgan sahte bir AP’yi tanıtır ve yasal bir AP ile aynı SSID ile yapılandırır.

Bir MITM saldırısını yenmek, WLAN’daki meřru cihazları tanımlamakla bařlar. Bunu yapmak iin kullanıcıların kimlięi doęrulanmalıdır. Tm meřru cihazlar bilindikten sonra, aę anormal cihazlar veya trafik aısından izlenebilir.

WLAN Gvenlięi

Genel olarak eriřim kablosuz, havadan yapıldıęından dikkat edilmezse istenmeyen kiřilerin de aynı aęda olması kaınılmazdır. Bu nedenle “gvenlik” kablosuz aęlar iin zerinde durulması gereken en nemli konulardan biridir.

- Noktadan, noktaya mikro dalga iletim sistemleri izlenmesi ok zor bir haberleřme yntemidir ancak bir noktadan ok noktaya iletimler teknik aıdan izlenmesi daha kolay bir haberleřme yntemidir.
- Bu tr sistemlerde dahili kriptolama zellikleri mevcut olmasına raęmen son yıllarda yapılan arařtırmalar bu tr sistemlerin saldırıya karřı sanıldıęından daha zayıf olduęunu gstermiřtir.
- Gvenlięi artırmak iin en basit yaklařım VPN teknolojilerinin, kablosuz haberleřme sistemleri ile birlikte kullanılmasıdır ancak bu yaklařım maaliyetlerin artmasına neden olmaktadır.

Kablosuz Aęları Gvenli Hale Getirme

SSID Gizleme ve MAC Adres Filtreleme

Kablosuz davetsiz misafirleri uzak tutma ve verileri koruma tehditlerini gidermek iin eskiden iki gvenlik zellięi kullanılırdı ve oęu ynlendirici ve AP’de hala kullanılabilir:

SSID Gizleme – AP’ler ve bazı kablosuz ynlendiriciler SSID iřaret erevesinin devre dıřı bırakılmasına izin verir. Kablosuz istemciler, aęa baęlanmak iin SSID ile manuel olarak yapılandırılmalıdır.

SSID eriřim noktalarının (Access Point) tanımlayıcı adıdır. Eriřim noktaları ortamdaki kablosuz cihazların kendisini bulabilmesi iin kendilerini devamlı anons ederler. Gvenlik nlemi olarak bu anonsları yaptırmayabiliriz. Bylece sadece eriřim noktasının adını bilen cihazlar aęa dahil olabilirler.

MAC Adresi Filtreleme – Yönetici, fiziksel MAC donanım adreslerine göre istemcilerin kablosuz erişimine el ile izin verebilir veya reddedebilir. Farklı MAC adreslerine sahip cihazlar 2.4 GHz WLAN'a katılamaz.

Diğer bir tanımı; bu metot AP ile iletişim kurmaya izin verilmiş kullanıcıların, kablosuz ağ kartlarının MAC adreslerinin listelenmesi ve kullanılmasıdır.

802.11 Orijinal Kimlik Doğrulama Yöntemleri

Kablosuz bir ağın güvenliğini sağlamanın en iyi yolu kimlik doğrulama ve şifreleme sistemlerini kullanmaktır. Orijinal 802.11 standardıyla iki tür kimlik doğrulama yapılmıştır:

Open system authentication – Açık sistem kimlik doğrulaması

- Şifre gerekmez. Genellikle kafe, havaalanı ve otel gibi ortak alanlarda ücretsiz internet erişimi sağlamak için kullanılır.
- İstemci, VPN ile güvenlik sağlamaktan sorumludur.

Shared key authentication – Paylaşılan anahtar kimlik doğrulaması

- Kablosuz bir istemci ile AP arasındaki verilerin kimliğini doğrulamak ve şifrelemek için WEP, WPA, WPA2 ve WPA3 gibi mekanizmalar sağlar. Ancak, bağlanmak için parolanın her iki taraf arasında önceden paylaşılması gerekir.

Not: **Radius ve 802.1x güvenlikleri**, kurumsal olarak kullanılan en güvenli yöntemlerdir. Bu yöntemde Access Point'ler kendilerine bağlanmak isteyen kullanıcıları yalnızca şifre ile değil, gidip cihazlarının ya da kimlik bilgilerinin **Active Directory** de olup olmadıklarını bile kontrol edebilirler.

Shared Key Authentication Methods – Paylaşılan Anahtar Kimlik Doğrulama Yöntemleri

Tabloda gösterildiği gibi 4 adet paylaşılan anahtar kimlik doğrulama tekniği mevcuttur.

Kimlik Doğrulama Yöntemi	Açıklama
Wired Equivalent Privacy (WEP)	Statik bir anahtarla Rivest Cipher 4 (RC4) şifreleme yöntemini kullanarak verileri korumak için tasarlanmış orijinal 802.11 spesifikasyonu. WEP artık önerilmemektedir ve asla kullanılmamalıdır.
Wi-Fi Protected Access (WPA)	WEP kullanan ancak verileri çok daha güçlü Geçici Anahtar Bütünlüğü Protokolü (TKIP-Temporal Key Integrity Protocol) şifreleme algoritmasıyla koruyan bir Wi-Fi Alliance standardı. TKIP, her paketin anahtarın değiştirilerek hacklemeyi çok daha zor hale getirir.
WPA2	Şifreleme için Gelişmiş Şifreleme Standardını (AES – Advanced Encryption Standard) kullanır. AES şu anda en güçlü şifreleme protokolü olarak kabul edilmektedir.
WPA3	Bu, yeni nesil Wi-Fi güvenliğidir. Tüm WPA3 özellikli cihazlar en son güvenlik yöntemlerini kullanır, eski protokollere izin vermez ve Korumalı Yönetim Çerçevelerinin (PMF – Protected Management Frames) kullanılmasını gerektirir.

Authenticating a Home User – Ev Kullanıcısının Kimliği Doğrulama

Ev yönlendiricileri genellikle kimlik doğrulama için iki seçeneğe sahiptir: WPA ve WPA2; WPA2 iki kimlik doğrulama yöntemine sahiptir.

- **Personal** – Ev veya küçük ofis ağları için kullanıcılar önceden paylaşılan anahtar (PSK) kullanarak kimlik doğrulaması yapar. Kablosuz istemciler, önceden paylaşılan bir parola kullanarak kablosuz yönlendirici ile kimlik doğrulaması yapar. Özel bir kimlik doğrulama sunucusu gerekmez.
- **Enterprise** – Kurumsal ağlar için tasarlanmıştır. RADIUS kimlik doğrulama sunucusu gerektirir. Ayrıştırıcı RADIUS sunucusu tarafından doğrulanması ve ardından kullanıcıların kimlik doğrulaması için Genişletilebilir Kimlik Doğrulama Protokolü'nü (EAP-Extensible Authentication Protocol) kullanan 802.1x standardını kullanarak kimlik doğrulaması yapması gerekir.

5GHz: ☒ Enable Sharing Network

Network Name (SSID): ☐ Hide SSID

Security: ← 6

Version: ← 7

Password:

Transmit Power:

Channel Width:

Channel:

Mode:

[SUPPORT](#) [BACK TO TOP](#) [SAVE](#) ← 8

Şifreleme Yöntemleri

WPA ve WPA2 iki şifreleme protokolü içerir:

Temporal Key Integrity Protocol – Geçici Anahtar Bütünlüğü Protokolü (TKIP) –

WPA tarafından kullanılır ve eski WLAN ekipmanı için destek sağlar. WEP kullanır ancak TKIP kullanarak katman 2 yükünü şifreler.

Advanced Encryption Standard (AES) – WPA2 tarafından kullanılır ve hedef bilgisayarların şifrelenmiş ve şifrelenmemiş bitlerin değiştirilip değiştirilmediğini algılamasını sağlayan, Blok Zincirleme İleti Kimlik Doğrulama Kodu Protokolü (CCMP – Counter Cipher Mode with Block Chaining Message Authentication Code Protocol) ile Sayaç Şifreleme Modu’nu kullanır.

Security Mode:

Channel Selection:

Channel:

Network Password:

- Open (risky)
- WEP 64 (risky)
- WEP 128 (risky)
- WPA-PSK (TKIP)
- WPA-PSK (AES)
- WPA2-PSK (TKIP)
- WPA2-PSK (AES)**
- WPAWPA2-PSK (TKIP/AES) (recommended)

Kurumsal Yapılarda Kimlik Doğrulama

Kurumsal güvenlik modu seçimi için bir Kimlik Doğrulama, Yetkilendirme ve Muhasebe (AAA) RADIUS sunucusu gerekir.

Gerekli bilgiler:

- RADIUS server IP address - Radius Sunucunun IP adresi.
- UDP port numbers – RADIUS Kimlik Doğrulaması için 1812 ve RADIUS Muhasebesi için 1813 numaralı UDP bağlantı noktaları, ancak 1645 ve 1646 numaralı UDP bağlantı noktalarını kullanarak da çalışabilir.
- Shared key – AP'nin RADIUS sunucusuyla kimliğini doğrulamak için kullanılır.

NOT: Kullanıcı kimlik doğrulaması ve yetkilendirmesi, son kullanıcıların merkezi, sunucu tabanlı kimlik doğrulamasını sağlayan 802.11x standardı tarafından gerçekleştirilir.

FortiDDoS 1500F FortiDDoS-1500F

Authentication

RADIUS

RADIUS Server Configuration

Status: ☒

Primary Server IP:

Primary Server Secret:

Port: (Range: 1 - 65535)

Secondary Server IP:

Secondary Server Secret:

Authentication Protocol:

Test Connectivity

Default Access Strategy for Remote RADIUS User

Access Profile:

Trusted Host: (Example: 192.3.2.5/24 or 2001:0db8:85a3:8a2e:0370::7334/64)

Save Refresh

WPA3

WPA2 artık güvenli kabul edilmediğinden, mümkünse WPA3 önerilir. WPA3 dört özellik içerir:

WPA3 – Personal: Simultaneous Authentication of Equals (SAE) kullanarak brute force saldırılarını engeller.

WPA3 – Enterprise: 802.1x / EAP kimlik doğrulamasını kullanır. Ancak, 192 bit şifreleme paketinin kullanılmasını gerektirir ve önceki 802.11 standartları için güvenlik protokollerinin karıştırılmasını ortadan kaldırır.

Open Networks: Herhangi bir kimlik doğrulama kullanmaz. Ancak, tüm kablosuz trafiği şifrelemek için Opportunistic Wireless Encryption (OWE) kullanır.

IoT Onboarding: IoT cihazlarını hızlı bir şekilde yerleştirmek için Device Provisioning Protocol (DPP) kullanır.